

VirtuEx 시스템 감사 보고서 (5차)

프로젝트: VirtuEx - 가상 자산 모의 거래 플랫폼 차수: 5차 감사 (4차 수정 검증) 작성일: 2026-03-02 작성: 시스템 감사팀

1. 개요

5차 감사는 4차 감사에서 발견된 79건의 이슈에 대한 수정 검증 감사입니다. 각 이슈의 수정 여부를 코드 레벨에서 확인하고, 빌드 성공 여부를 검증했습니다.

1.1 검증 범위

영역	4차 발견	수정 완료	미수정
보안 (백엔드 + 인프라 + 프론트엔드)	12건	12건	0건
데이터 무결성	8건	8건	0건
성능	7건	7건	0건
코드 품질 — 백엔드	7건	7건	0건
인프라/빌드/환경	24건	24건	0건
프론트엔드 코드 품질	5건	5건	0건
프론트엔드 i18n	9건	9건	0건
프론트엔드 접근성	3건	3건	0건
프론트엔드 상태/UX	4건	4건	0건
합계	79건	79건	0건

2. 보안 감사 검증 (12건)

#	항목	검증 결과	수정 내용
1	Settings 프록시 전체 헤더 전달	✓	headers: { authorization: req.headers.authorization }로 변경
2	페이지뷰 트래킹 path 미검증	✓	TrackPageViewDto 추가 (@MaxLength(500) + @Matches 검증)
3	환경 파일 Git 추적	✓	.gitignore 추가 + git rm --cached 실행
4	시드 파일 개인정보 하드코딩	✓	비밀번호/주민번호/전화번호/이름/주소 모두 가상 데이터로 교체
5	accessToken localStorage 저장	✓	partialize에서 accessToken 제거, 메모리만 유지
6	viewCount 무인증 무제한 증가	✓	@UseGuards(ThrottlerGuard) + @Throttle 적용 (60초 당 10회)

7	Email 에러 로그 이메일 노출	✓	에러 경로에서도 마스킹 적용
8	ThrottlerModule ConfigService 미사용	✓	ConfigService에서 THROTTLE_TTL/THROTTLE_LIMIT 읽도록 변경
9	price-subscriber 빈 catch	✓	this.logger.warn('refreshAlerts failed', ...) 추가
10	채팅방 join-room 권한 미검증	✓	userId 기반 방 참여자 확인 로직 추가
11	statistics page-view 프록시 미인증	✓	ThrottlerGuard + x-internal-token 전달 추가
12	Next.js 보안 헤더 불완전	✓	HSTS + CSP 헤더 추가

3. 데이터 무결성 검증 (8건)

#	항목	검증 결과	수정 내용
13	MARKET_DATA_URL 기본값 오류	✓	http://localhost:3003 → http://localhost:3001
14	Settings bulkUpdate 트랜잭션 미적용	✓	prisma.\$transaction(...) 배열 트랜잭션 적용
15	order.service any 타입	✓	Prisma.OrderReadWhereInput 타입 적용
16	announcement.service 댓글 any	✓	Prisma include 결과 타입으로 교체
17	order.service withRetry any	✓	catch (error: unknown) + 타입 가드 적용
18	balance.service any 타입	✓	Decimal 타입 명시
19	\$executeRawUnsafe 사용	✓	\$executeRaw 태그드 템플릿으로 변경
20	statistics period 파라미터 미검증	✓	PeriodQueryDto 추가 (@IsInt() @Min(1) @Max(365))

4. 성능 검증 (7건)

#	항목	검증 결과	수정 내용
21	getTradingStats 메모리 로드	✓	Prisma groupBy + _sum/_count DB 집계로 변경
22	statistics 대량 레코드 로드	✓	days 상한 365일, DB groupBy 집계 적용
23	aggregateHigherIntervals N+1	✓	where: { symbol: { in: symbols } } 배치 쿼리로 변경
24	fetchMarketPrices 내부 토큰 미전달	✓	x-internal-token 헤더 추가

25	채팅 통계 raw SQL bigint	✓	\$queryRaw 태그드 템플릿 + Number 변환
26	leaderboard 비효율 fetch	✓	쿼리 간소화
27	news scrapeAll isScraping 플래그	✓	onModuleInit에서 isScraping 설정/해제

5. 코드 품질 — 백엔드 검증 (7건)

#	항목	검증 결과	수정 내용
28	validateHoldings any 타입	✓	catch (error: unknown) + 타입 가드
29	reserveFunds any 타입	✓	catch (error: unknown) + 타입 가드
30	MatchingEngine 오더북 복구	✓	onModuleInit() 추가 — PENDING/PARTIAL 주문 DB 로드
31	Announcement 알림 실패 무시	✓	try/catch + this.logger.warn 추가
32	news.service 빈 catch	✓	this.logger.warn('News item processing failed', ...)
33	TOTP 브루트포스 방지	✓	Redis 기반 시도 횟수 제한 (5회 실패 → 5분 잠금)
34	chat deleteRoom 트랜잭션	✓	prisma.\$transaction([...]) 원자적 처리

6. 인프라/빌드/환경 검증 (24건)

6.1 Docker (5건)

#	항목	검증 결과	수정 내용
35	docker-compose.yml version 키	✓	version: '3.9' 삭제
36	Redis 인증 미적용	✓	--requirepass \${REDIS_PASSWORD:-redis} 추가
37	모니터링 헬스체크 미설정	✓	Prometheus/Grafana/Jaeger 각각 healthcheck 추가
38	모니터링 리소스 제한 미설정	✓	deploy.resources.limits (memory, cpus) 추가
39	PostgreSQL healthcheck 환경변수	✓	pg_isready -U \${POSTGRES_USER:-postgres}

6.2 빌드 설정 (5건)

#	항목	검증 결과	수정 내용
40	NestJS 보조 패키지 버전 불일치	✓	@nestjs/config ^4.0.0, @nestjs/cqrs ^11.0.0, @nestjs/terminus ^11.0.0 정렬
41	class-validator 버전 불일치	✓	notification ^0.14.1로 통일
42	@prisma/client 버전 불일치	✓	chat ^6.3.0으로 통일
43	chat Prisma DB 스크립트 누락	✓	db:push, db:generate 스크립트 추가
44	turbo.json outputs Prisma 미포함	✓	"generated/**" 추가

6.3 데이터베이스 (3건)

#	항목	검증 결과	수정 내용
45	데이터 보존 정책 부재	✓	scripts/cleanup-old-data.sh 생성 (90일 보존)
46	Event Store Outbox 정리	✓	purgePublished(30) + 매일 03:00 Cron
47	Transaction type enum 미적용	✓	TransactionType enum 정의 + 스키마 적용

6.4 환경변수 (5건)

#	항목	검증 결과	수정 내용
48	.env.example CORS_ORIGIN 누락	✓	CORS_ORIGIN=http://localhost:4000 추가
49	.env.example MARKET_DATA_URL 누락	✓	MARKET_DATA_URL, PORTFOLIO_URL 추가
50	.env.example GRAFANA_ADMIN_USER 누락	✓	GRAFANA_ADMIN_USER=admin 추가
51	환경별 인증 설정 누락	✓	SALT_ROUNDS, THROTTLE_TTL, THROTTLE_LIMIT 추가
52	.env 개인 연락처 하드코딩	✓	플레이스홀더로 교체

6.5 스크립트 (4건)

#	항목	검증 결과	수정 내용
53	Kafka 토픽명 불일치	✓	market.prices.updated orders.events trades.executed로 수정
54	backup-db.sh 단일 DB	✓	6개 서비스 DB 순회 백업으로 변경

55	스크립트 프로젝트 경로 오류	✓	virtuex → project-virtuex
56	BigInt.prototype.toJSON 전역 변경	✓	제거 → BigIntSerializerInterceptor 적용

6.6 모니터링 (2건)

#	항목	검증 결과	수정 내용
57	Prometheus 알람 규칙 미설정	✓	alert-rules.yml 생성 (ServiceDown, HighLatency, HighErrorRate)
58	Grafana 데이터 소스 프로비저닝	✓	datasource.yml 생성 + 볼륨 마운트

7. 프론트엔드 검증 (21건)

7.1 코드 품질 (5건)

#	항목	검증 결과	수정 내용
59	useLeaderboard any []	✓	LeaderboardEntry 인터페이스 정의
60	로그인 user: any	✓	타입 명시 + as User 캐스팅
61	대시보드 as any []	✓	Omit<Asset, ...> 타입 적용
62	Recharts label any	✓	{ name?: string; percent?: number } 타입 명시
63	PageViewTracker eslint-disable	✓	useRef 패턴으로 deps 정상화

7.2 i18n (9건)

#	항목	검증 결과	수정 내용
64	ChatPanel 나가기 확인 한국어	✓	t('chat.confirmLeaveRoom')
65	MessageArea '(me)' 영어	✓	t('chat.me')
66	MessageArea 'Kick' 영어	✓	t('chat.kick') (기존 키 활용)
67	useChat 전송 실패 한국어	✓	t('chat.sendFailed') + useTranslation 추가
68	AIInsights 에러 한국어	✓	t('ai.loadError')
69	MobileMenuButton aria-label 한국어	✓	t('common.openMenu') + useTranslation 추가
70	관리자 설정 실패 한국어	✓	t('admin.settings.saveFailed')
71	마이페이지 알람 실패 한국어	✓	t('mypage.notificationSaveFailed') + 컴포넌트에 useTranslation 추가

72	OrderBook 'No data' 영어	✓	t('common.noData') (기존 키 활용)
----	------------------------	---	------------------------------

7.3 접근성 (3건)

#	항목	검증 결과	수정 내용
73	OrderSheet 모달 role 누락	✓	role="dialog" aria-modal="true" 추가
74	SpotlightSearch 모달 role 누락	✓	role="dialog" aria-modal="true" 추가
75	비밀번호 모달 ARIA/포커스 트랩	✓	role="dialog" aria-modal="true" + Tab 포커스 트랩 추가

7.4 상태 관리 / UX (4건)

#	항목	검증 결과	수정 내용
76	MessageArea eslint-disable	✓	deps에 markRead 추가, eslint-disable 제거
77	공지사항 eslint-disable	✓	deps에 incrementViewCount 추가, eslint-disable 제거
78	PinnedChatPanel 확인 없음	✓	confirm(t('chat.confirmLeaveRoom')) 추가
79	PhoneVerification 영어 하드코딩	✓	t('auth.sendCodeFailed')

8. 빌드 검증

서비스	빌드 결과
Frontend (Next.js)	✓ next build 성공
Backend 서비스 (tsc)	✓ 타입 체크 통과

9. 종합 평가

9.1 수정 현황

위험도	4차 발견	수정 완료	잔여
상	8	8	0
중	48	48	0
하	23	23	0
합계	79	79	0

9.2 영역별 성숙도 (수정 후)

항목	수정 전	수정 후	개선
보안	3.0/5	4.5/5	+1.5
데이터 무결성	3.5/5	4.5/5	+1.0
성능	3.5/5	4.5/5	+1.0
인프라	3.5/5	4.5/5	+1.0
빌드/환경	3.5/5	4.5/5	+1.0
프론트엔드 코드	3.5/5	4.5/5	+1.0
i18n	3.0/5	4.5/5	+1.5
접근성	3.5/5	4.5/5	+1.0
종합	3.3/5	4.5/5	+1.2

9.3 누적 감사 현황

차수	발견	수정	스킵	미수정
1차	36	36	0	0
2차	50	45	4	1
3차	0 (검증)	-	-	-
4차	79	79	0	0
5차	0 (검증)	-	-	-
누적	165	160	4	1

9.4 결론

4차 감사에서 발견된 79건의 이슈가 모두 수정 완료되었습니다. 보안, 데이터 무결성, 성능, 코드 품질, 인프라, 프론트엔드 전 영역에서 개선이 이루어졌으며, 프론트엔드 빌드가 정상 통과함을 확인했습니다.

주요 개선 사항:

- **보안:** 환경 파일 Git 추적 해제, PII 제거, accessToken 메모리 전환, TOTP 브루트포스 방지, CSP/HSTS 헤더
- **성능:** DB 집계 전환 (메모리 로드 제거), N+1 쿼리 해소, 오더북 자동 복구
- **코드 품질:** any 타입 12건 제거, eslint-disable 3건 제거, 트랜잭션 적용
- **인프라:** Redis 인증, 모니터링 헬스체크/리소스 제한, Kafka 토픽 정렬, Prometheus 알림
- **프론트엔드:** i18n 하드코딩 9건 해소, 모달 접근성 3건, UX 개선 2건

본 보고서는 VirtuEx 시스템의 5차 감사(4차 수정 검증) 결과입니다. 2026-03-02 기준 소스 코드를 대상으로 합니다.